

Access Control Policy - SecurePay

Version: 1.0

Effective Date: 2025-06-12

Review Date: 2026-06-12

Prepared by: Ubuntu GRC

Executive Snapshot

- **Scope:** Governs all forms of access (physical, logical, remote) to SecurePay's information assets for all personnel and third parties.
- **Core Objective:** Protects confidentiality, integrity, and availability of information by implementing least privilege and need-to-know principles.
- **Key Controls:** Enforces strong authentication (MFA), network segregation, privileged access management, and regular access reviews.
- **Regulatory Alignment:** Supports POPIA compliance by ensuring robust security safeguards for personal information.
- **Business Benefit:** Minimizes unauthorized access risks, enhances data protection, and strengthens overall security posture.

1. Introduction

This Access Control Policy establishes the framework for managing access to SecurePay's information systems, applications, and data. Its purpose is to protect the confidentiality, integrity, and availability of SecurePay's information assets by ensuring that only authorized individuals have access to necessary resources, based on their roles and responsibilities. This policy aligns with ISO 27001:2022 Annex A controls and the principles of the Protection of Personal Information Act (POPIA).

2. Scope

This policy applies to all SecurePay employees, contractors, temporary staff, and third parties who require access to SecurePay's information assets. It covers all forms of access, including physical, logical, and remote access, to all systems, applications, networks, and data, regardless of their location or storage medium.

3. Principles of Access Control

SecurePay's access control framework is built upon the following principles:

- Least Privilege: Users will be granted the minimum level of access necessary to perform their job functions and no more.
- Need-to-Know: Access to sensitive information will be restricted to only those individuals who require it to perform their legitimate duties.
- Segregation of Duties (SoD): Conflicting duties and responsibilities will be separated to reduce the risk of fraud or error.
- Accountability: All access activities will be logged and auditable to ensure accountability.
- Regular Review: Access rights will be regularly reviewed and updated to reflect changes in roles, responsibilities, or employment status.

4. Access Control Requirements

4.1. User Access Management

- User Registration and De-registration: A formal process will be in place for registering new users and de-registering users upon termination or change of role. Access will be provisioned and de-provisioned promptly.
- Unique User IDs: Each user will be assigned a unique user ID for accountability.
- Password Management: Strong password policies will be enforced, requiring complex passwords, regular changes, and prohibiting reuse. Multi-factor authentication (MFA) will be implemented for all critical systems and remote access.
- Privileged Access Management: Access to privileged accounts (e.g., administrator, root) will be strictly controlled, monitored, and logged. Privileged access will be granted only for specific, approved tasks and for limited durations.

4.2. System and Application Access

- Access Control Lists (ACLs): Access to systems, applications, and data will be controlled using ACLs or similar mechanisms based on user roles and permissions.
- Secure Log-on Procedures: Secure log-on procedures will be implemented to protect against unauthorized access, including session timeouts and protection against brute-force attacks.
- Application Access Control: Access within applications will be managed to ensure users can only perform functions and access data relevant to their role.

4.3. Network Access Control

- Network Segregation: Networks will be segmented to isolate critical systems and sensitive data, limiting the impact of security breaches.
- Firewalls and Intrusion Detection/Prevention Systems (IDPS): Firewalls and IDPS will be deployed and configured to control network traffic and detect/prevent unauthorized access attempts.
- Remote Access: Secure remote access solutions (e.g., VPN with MFA) will be used for all remote connections to SecurePay's network.

4.4. Physical Access Control

- Physical Security: Physical access to SecurePay's premises, data centers, and secure areas will be controlled through appropriate measures such as access cards, biometric systems, and surveillance.
- Visitor Access: Visitor access will be managed and monitored, and visitors will be escorted in secure areas.

4.5. Third-Party Access

- Vendor Access: Third-party access to SecurePay's systems and data will be granted only after a thorough risk assessment and under strict contractual agreements. Access will be limited to specific systems and data required for their services and will be regularly reviewed.
- Service Level Agreements (SLAs): SLAs with third-party providers will include clauses on information security and access control requirements.

5. Monitoring and Review

- Access Log Review: All access logs will be regularly reviewed for suspicious activities or unauthorized access attempts.
- Periodic Access Review: User access rights will be reviewed periodically (e.g., quarterly, semi-annually) to ensure they remain appropriate and align with current job functions.
- Audit Trails: Comprehensive audit trails will be maintained for all access activities to facilitate investigations and compliance audits.

6. POPIA Alignment

This policy supports SecurePay's compliance with POPIA by ensuring that personal information is protected through robust access controls, thereby upholding the principles of security safeguards and processing limitation.

7. Policy Review

This policy will be reviewed at least annually, or more frequently if there are significant changes to SecurePay's business operations, technology, or the legal and regulatory landscape. Any amendments to this policy must be approved by senior management.

8. Enforcement

Any violation of this policy may result in disciplinary action, up to and including termination of employment or contract, and may also lead to legal action.